

11 Defenses: Firewall & Intrusion Prevention

Outline

- Overview of firewall
- Types of firewall
- Firewall basing and location
- Intrusion prevention

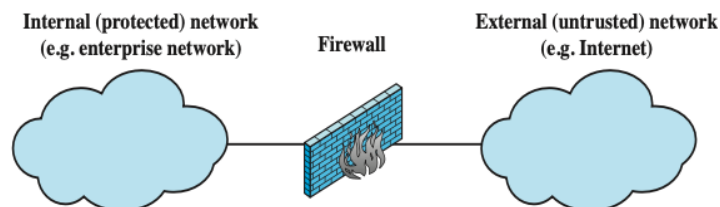
Learning objectives

- Understand the principle of firewall and its capabilities and limits
- Learn about various types of firewall.
- Learn about different basing and deployment of firewall
- Learn about intrusion prevention system.

Overview

Firewalls

- What is a firewall
- A firewall is a network security system that monitors and controls incoming and outgoing network traffic based on predetermined security rules.
- Typically establishes a barrier between a trusted network and an untrusted network, such as the Internet.



Firewall Design Goals

- All traffic from inside to outside, and vice versa, must pass through the firewall
- Only authorized traffic as defined by the local security policy will be allowed to pass
- The firewall itself is immune to penetration

Firewall Filter Characteristics

Characteristics that a firewall access policy could use to filter traffic include:

- IP address and protocol values
 - Based on the source or destination addresses and port numbers, direction of flow (inbound or outbound), and other network and transport layer characteristics
 - Used by packet filter and stateful inspection firewalls

- Typically used to limit access to specific services
- Application protocol
 - Controls access on the basis of authorized application protocol data.
 - Used by application- level gateways that relay and monitor the exchange of information for specific application protocols
- User Identity
 - Based on the identity of inside users
- Network activity
 - Controls access based on considerations such as the time of request, rate of requests, or other activity patterns

Firewall Capabilities and Limits

Capabilities:

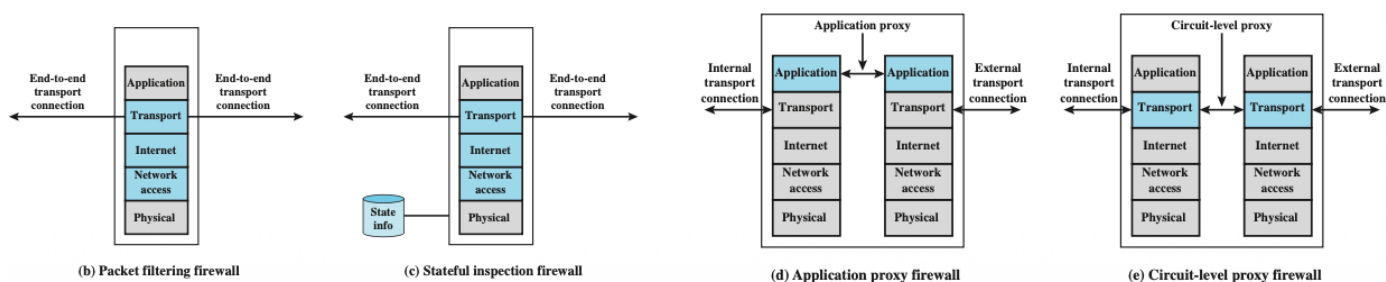
- Defines a single choke point
- Provides a location for monitoring security events (e.g., audits, alarms)
- Convenient platform for several Internet functions that are not security related, e.g., network address translator

Limitations:

- Cannot protect against attacks bypassing firewall
- May not protect fully against internal threats
- Laptop or portable storage device may be infected outside the corporate network then used internally

Types of firewalls

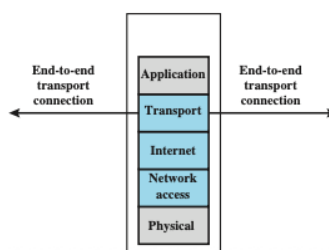
- A firewall can monitor network traffic at a number of levels
- Based on the levels of network traffics, firewalls can be categorized into the following types:



Packet Filtering Firewall

- Applies rules to each incoming and outgoing IP packet
 - Is typically set up as a list of rules based on matches in the IP or TCP header
 - Forwards or discards the packet based on rules match
- Two default policies:

- Discard - prohibit unless expressly permitted
 - More secure but can reduce availability
- Forward - permit unless expressly prohibited
 - Easier to manage and use but less secure
- Filtering rules are based on information contained in a network packet
 - Source IP address
 - Destination IP address
 - Source and destination transport-level address (e.g., TCP or UDP port number)
 - IP protocol field (e.g., 6 for TCP, 17 for UDP)
 - Interface



(b) Packet filtering firewall

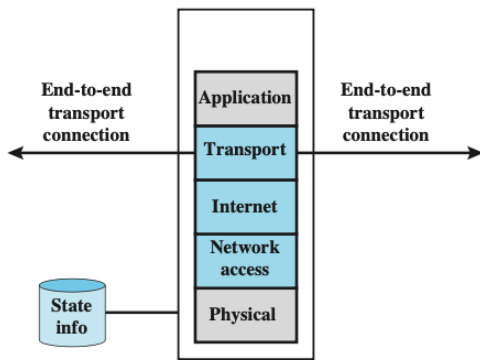
Packet-Filtering Firewall Example

- Simplified rule set for SMTP traffic.
- The goal is to allow inbound and outbound email traffic but to block all other traffic.

Rule	Direction	Src address	Src port	Dest address	Protocol	Dest port	Flag	Action
1	In	External		Internal	TCP	25		Permit
2	Out	Internal	25	External	TCP	>1023	ACK	Permit
3	Out	Internal		External	TCP	25		Permit
4	In	External	25	Internal	TCP	>1023	ACK	Permit
5	Either	Any		Any	Any	Any		Deny

Stateful Inspection Firewall

- Tightens rules for TCP traffic by creating a directory of **outbound TCP connections**
 - There is an entry for each currently established connection
 - Allow incoming traffic to high numbered ports only for those packets that fit the profile of one of the entries in this directory



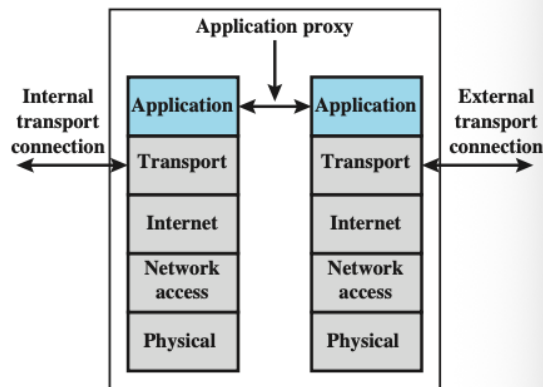
(c) Stateful inspection firewall

Example Stateful Firewall Connection State Table

Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	210.9.88.29	80	Established
192.168.1.102	1031	216.32.42.123	80	Established
192.168.1.101	1033	173.66.32.122	25	Established
192.168.1.106	1035	177.231.32.12	79	Established
223.43.21.231	1990	192.168.1.6	80	Established
219.22.123.32	2112	192.168.1.6	80	Established
210.99.212.18	3321	192.168.1.6	80	Established
24.102.32.23	1025	192.168.1.6	80	Established
223.21.22.12	1046	192.168.1.6	80	Established

Application-Level Gateway

- Also called an application proxy
- Acts as a relay of application-level traffic
 - E.g., Telnet, FTP
 - How it works:
 1. Client connects to the proxy gateway
 2. Gateway establishes a separate connection to the destination server
 3. Gateway inspects and filters application-layer payload (e.g., FTP commands, HTTP requests)



(d) Application proxy firewall

User contacts gateway using a TCP/IP application



User is authenticated

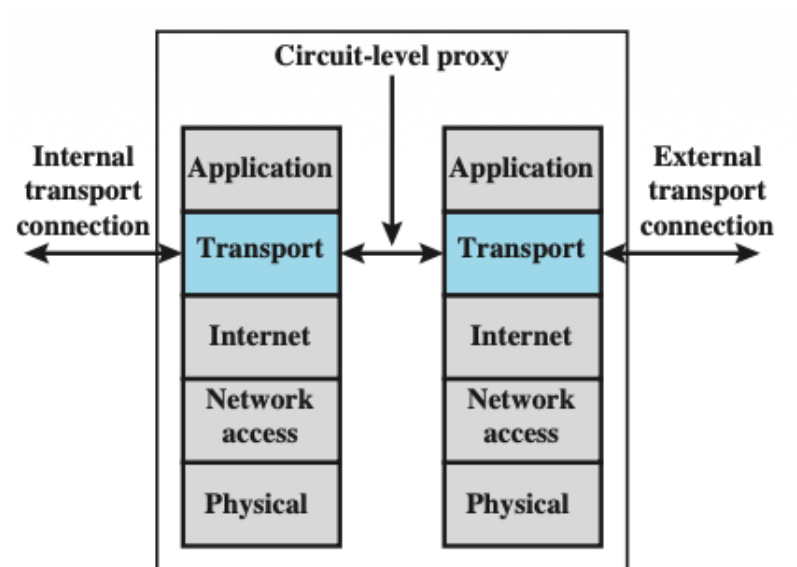


Gateway contacts application on remote host and relays TCP segments between server and user

Circuit-Level Gateway

- Also called circuit level proxy
- Sets up two TCP connections, one between itself and a TCP user on an inner host and one on an outside host

- Relays TCP segments from one connection to the other without examining contents
- Typically used when inside users are trusted
 - May use application-level gateway inbound and circuit-level gateway outbound



(e) Circuit-level proxy firewall

Firewall basing and location

Firewall Basing

- It is common to base a firewall on a stand-alone machine running a common operating system, such as UNIX or Linux.
- Firewall functionality can also be implemented as a software module in a router or LAN switch.
- Some additional firewall basing considerations.

Bastion Hosts:	Host-Based Firewalls	Personal Firewall
• Serves as a platform for an application-level or circuit-level gateway	• A software module used to secure an individual host. • A common location for such firewalls is a server.	• A software module on the personal computer, e.g., in home environment

Firewall Location and Configurations

Firewall Location and Configurations

DMZ: demilitarized zone

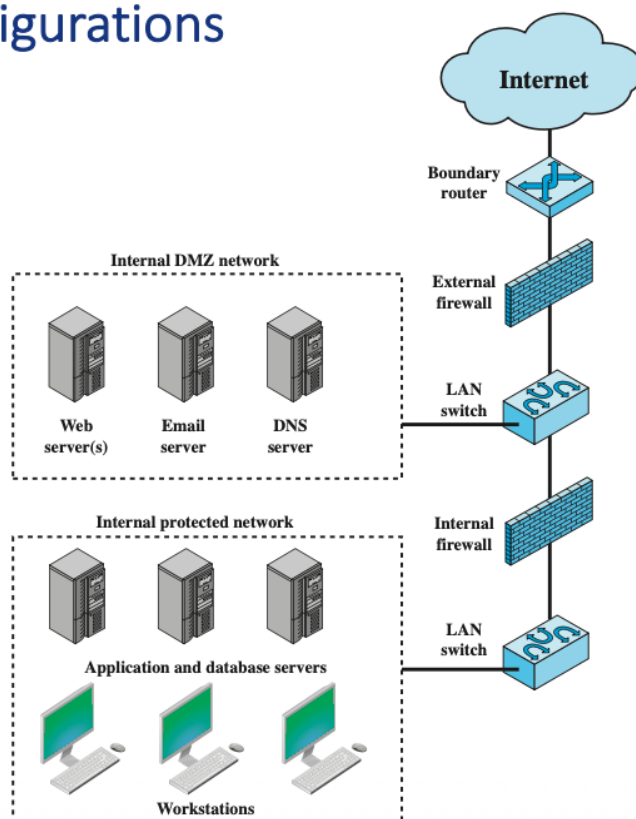
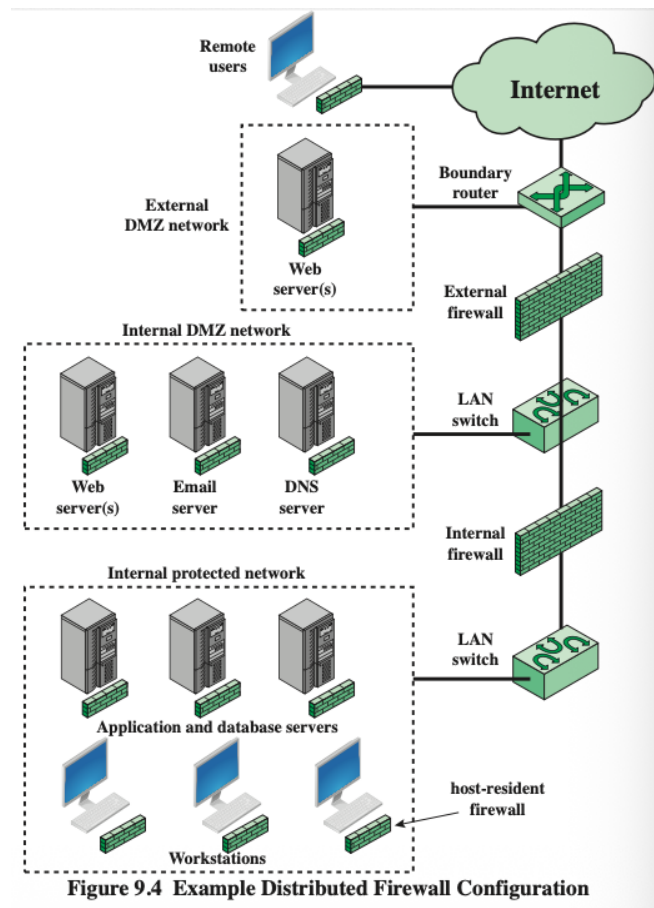


Figure 9.2 Example Firewall Configuration

Distributed Firewalls

- A distributed firewall configuration involves stand-alone firewall devices plus host-based firewalls working together under a central administrative control.
- Host-based firewalls
 - On hundreds of servers and workstation as well as personal firewalls on local and remote user systems.
 - Protect against internal attacks and provide protection specialized to specific machines and applications.
- Stand-alone firewalls provide global protection.



Intrusion Prevention

Intrusion Prevention Systems (IPS)

- Also known as Intrusion Detection and Prevention System (IDPS)
- Is an extension of an IDS that includes the capability to attempt to block or prevent detected malicious activity
- Can be host-based, network-based, or distributed/hybrid
- Can use anomaly detection to identify behavior that is not that of legitimate users, or signature/heuristic detection to identify known malicious behavior.
- Can block traffic as a firewall does but make use of the types of algorithms developed for IDSs to determine when to do so.